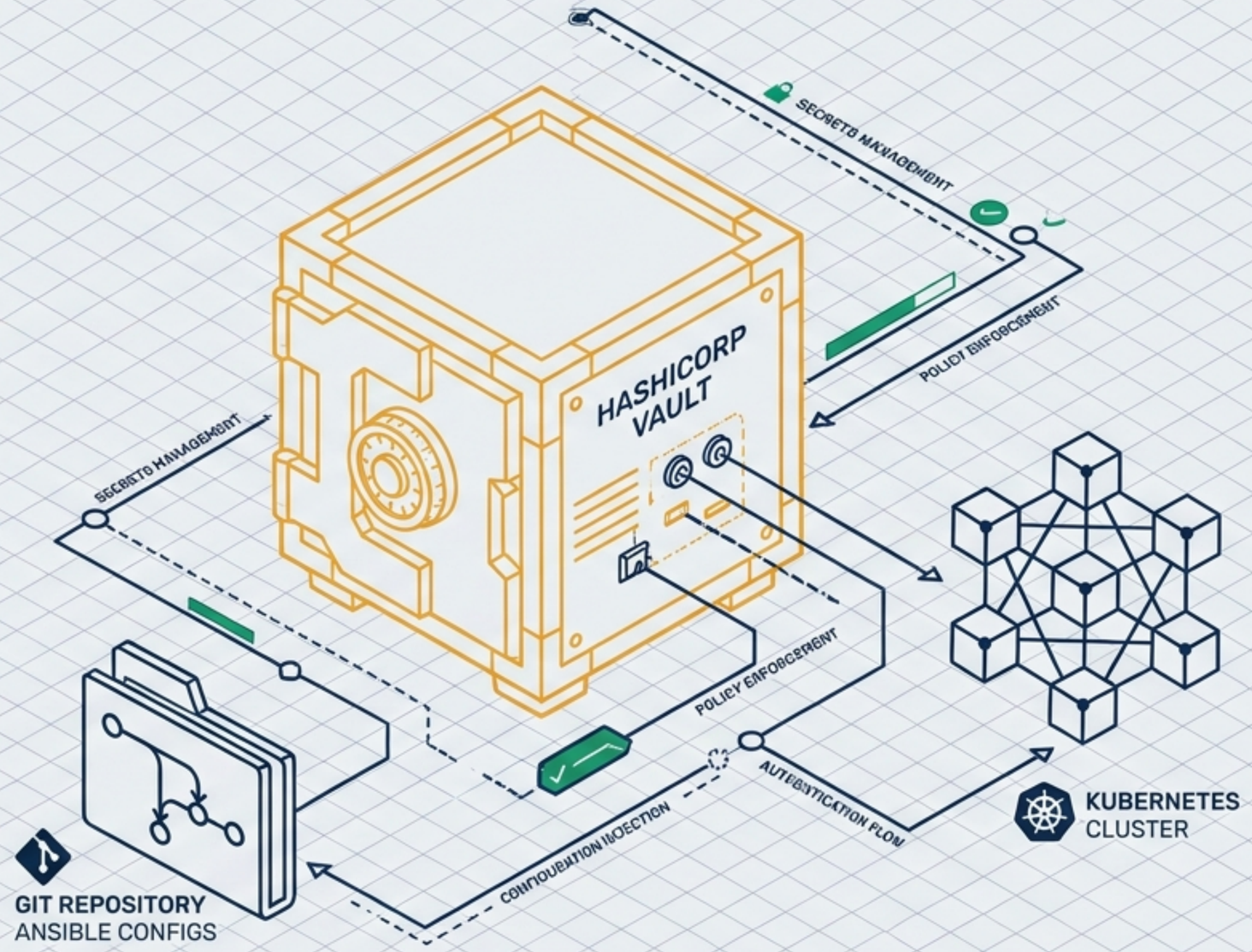
Fase III: Ejecución

Construyendo la Ciudadela DevSecOps

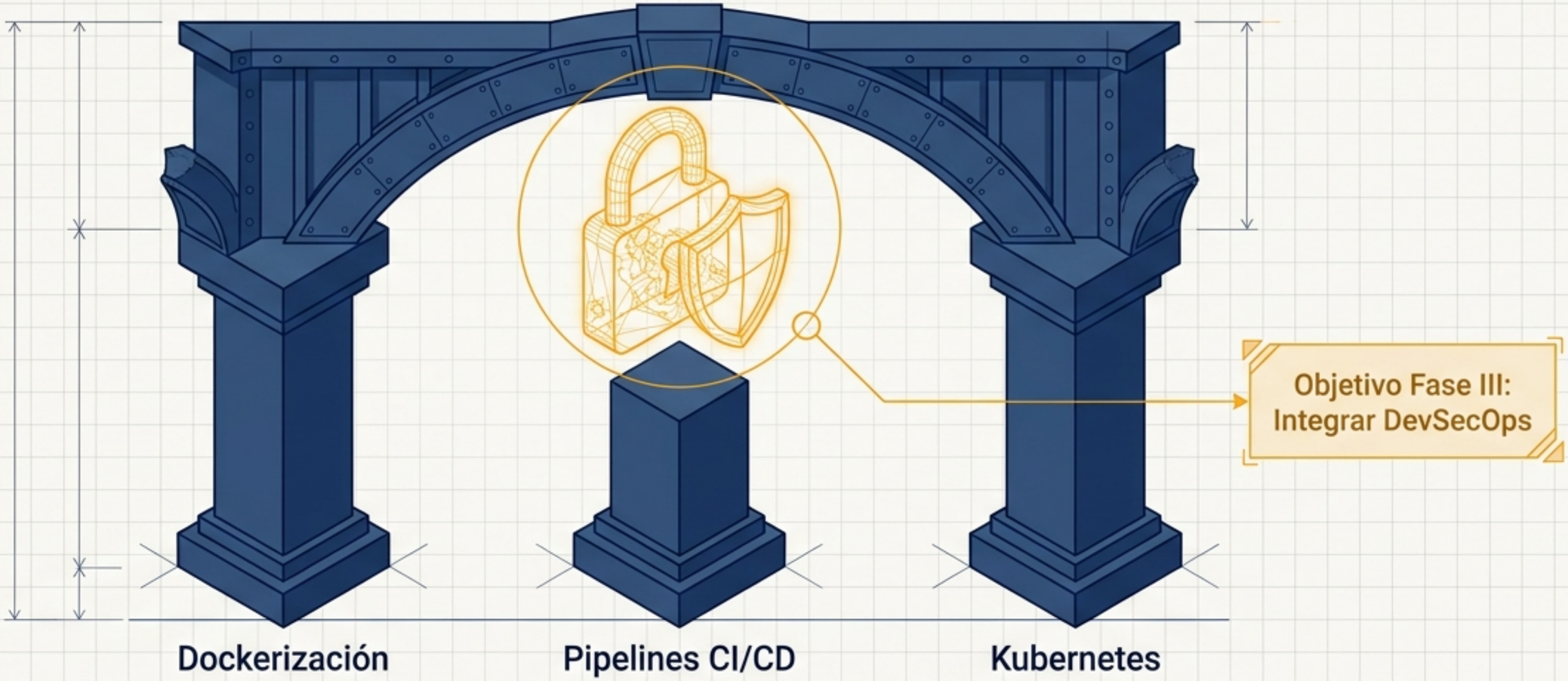
Plan táctico de 32 días para blindar nuestro ciclo de vida con HashiCorp Vault y Ansible.



Gemini Notebook

Nuestro Punto de Partida

Hemos construido una base infraestructural sólida y escalable. Sin embargo, nuestro ciclo de vida de desarrollo carece del elemento central que unifica y protege el ecosistema: un sistema de gestión de configuración y seguridad descentralizada.

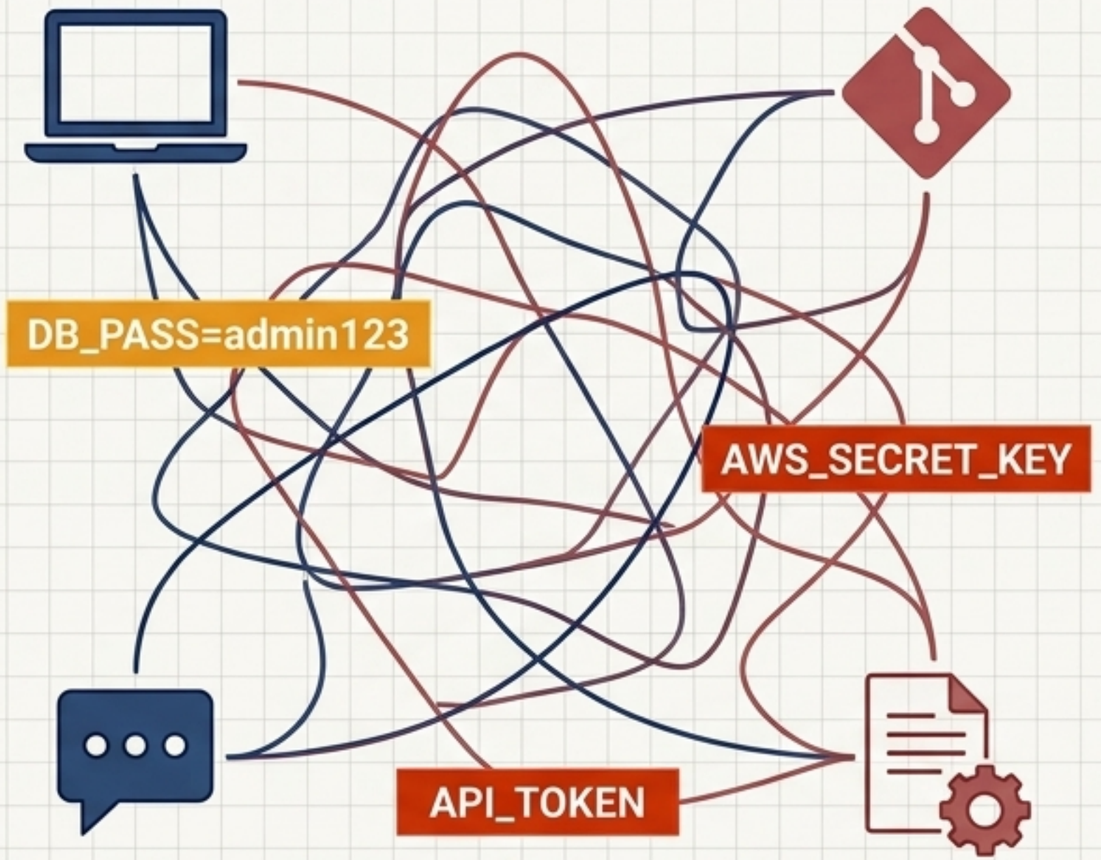


Gemini Notebook

El Enemigo Invisible: Secret Sprawl

Si nuestros secretos están en todas partes, no están seguros en ninguna.

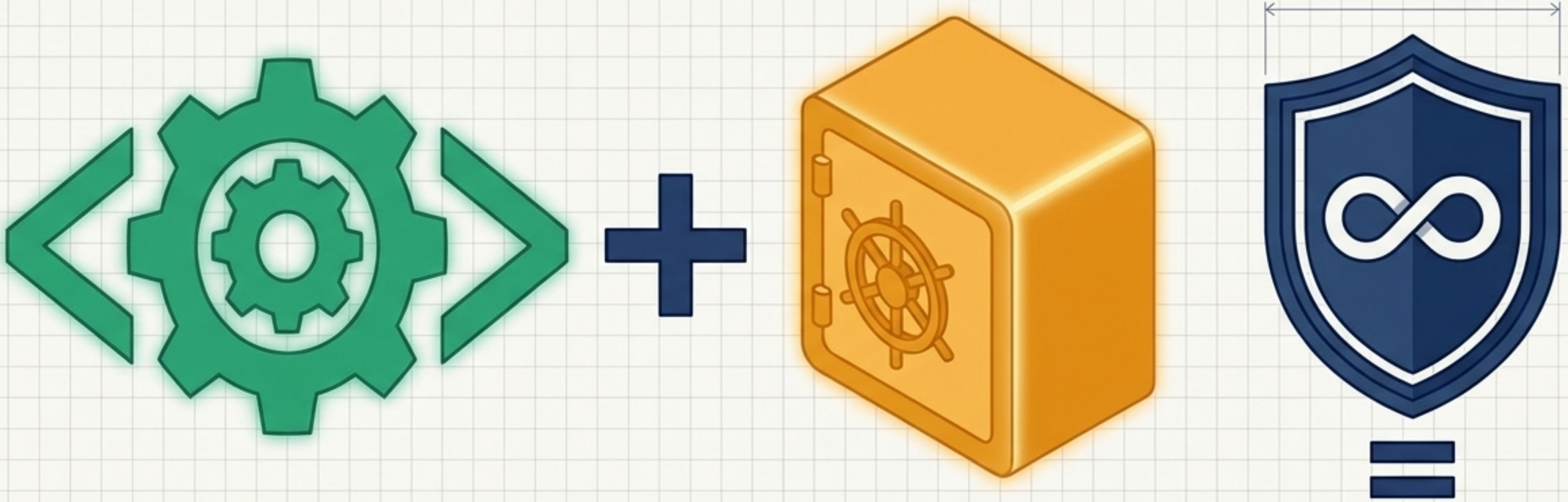
- Credenciales hardcodeadas en repositorios Git.
- Variables de entorno expuestas en pipelines de CI/CD.
- Claves compartidas en texto plano entre desarrolladores.



El código debe ser estrictamente configuración. Los valores sensibles deben abstraerse y protegerse en una **Única Fuente de Verdad.**

Gemini Notebook

La Solución DevSecOps



Automatización de Infraestructura (Ansible) + Seguridad Centralizada (Vault) = Ciclo de Vida Blindado

Gestionar la configuración e implementar políticas automatizadas para proveer la seguridad necesaria nativa a nuestro sistema en desarrollo.

Gemini Notebook

El Ecosistema Integrado



Ansible
(El Arquitecto)

Aprovisionamiento:
Ansible construye el entorno fuera del clúster K8s.



Git/GitHub



GitHub Actions
(El Transportista)



HashiCorp Vault
(La Bóveda)



Kubernetes
(El Destino)

Autenticación: GitHub Actions solicita acceso mediante un Token Único.

Inyección: Vault entrega el secreto dinámicamente en tiempo de ejecución.

Gemini Notebook

HashiCorp Vault: La Bóveda

Vault actúa como un broker de identidades, no solo como un disco duro de contraseñas.



Motor KV (Key-Value)

Almacenamiento estructurado genérico para nuestras credenciales.

Políticas ACL

Principio de menor privilegio estricto para cada aplicación.

El Sellado (Unseal)

Vault inicia bloqueado. Requiere llaves fragmentadas (Shamir's Secret Sharing) para reconstruir la llave maestra en memoria.

Gemini Notebook

Ansible: El Arquitecto Automatizado

La instalación manual es un riesgo de seguridad y un fracaso de escalabilidad.



Infraestructura como Código: Todo el estado del servidor reside en nuestro repositorio Git.

Idempotencia: El playbook se puede ejecutar 1 o 100 veces; el resultado siempre será el mismo estado deseado, permitiendo destruir y recrear sin miedo.

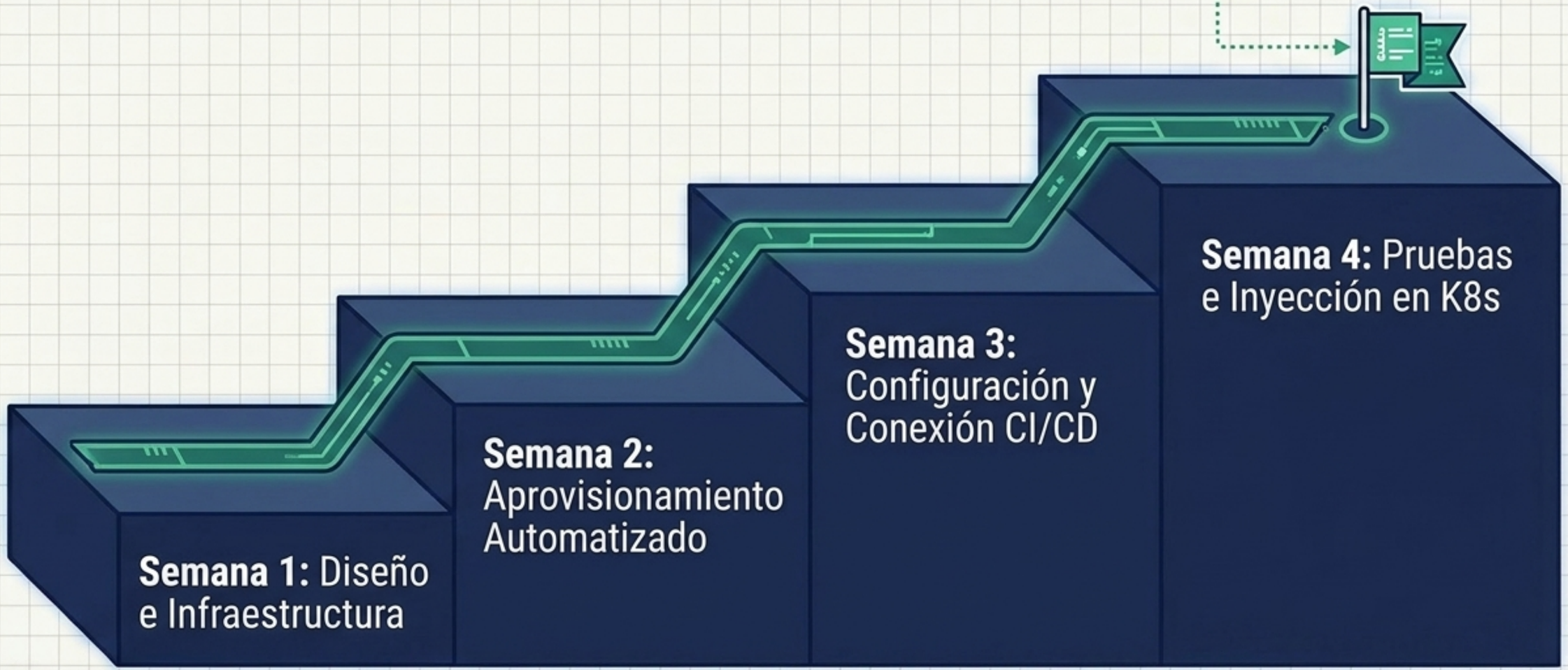
Modularidad: Uso de Roles o Playbooks estructurados para instalar dependencias, descargar Vault y configurar el listener web de forma automatizada.

Gemini Notebook

El Plan de Acción (32 Días)

29 de Septiembre – 30 de Octubre

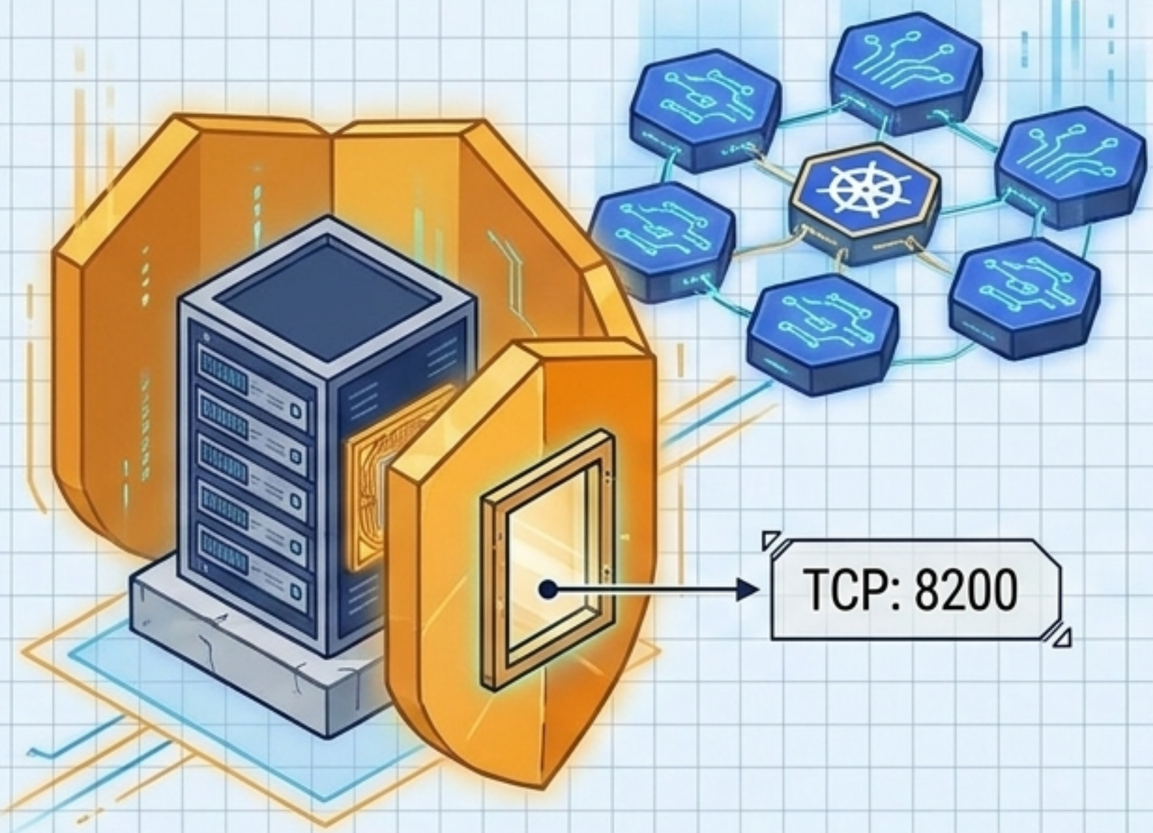
Un cronograma de construcción táctico sin desviaciones.



Gemini Notebook

Semana 1 | Diseño e Infraestructura

29 de Septiembre – 05 de Octubre



Paso 1: Provisionar instancia EC2 (AWS o proveedor preferido) fuera del clúster K8s actual.

Paso 2: Configurar Security Groups habilitando exclusivamente el acceso web por el puerto 8200.

Paso 3: Diseñar el flujo de secretos. Identificar qué variables en duro (ej. credenciales de BD) migrarán a Vault.

Paso 4: Documentar la topología propuesta en el Portafolio de Evidencias.

Gemini Notebook

Semana 2 | Aprovisionamiento Automatizado

06 – 13 de Octubre



Paso 4: Estructurar el repositorio Ansible (Roles o Playbooks modulares).

Paso 5: Escribir automatización para instalar dependencias/Vault, y configurar vault.hcl habilitando la UI (**ui = true**) y el listener.

Paso 6 (Prueba de Fuego): Demostrar idempotencia destruyendo el entorno completo y recreándolo automáticamente desde cero.

Gemini Notebook

Semana 3 | Configuración y Conexión CI/CD

14 – 21 de Octubre







Paso 7: Inicializar Vault, desprecintarlo (Unseal), habilitar el motor KV y validar acceso a la UI web.

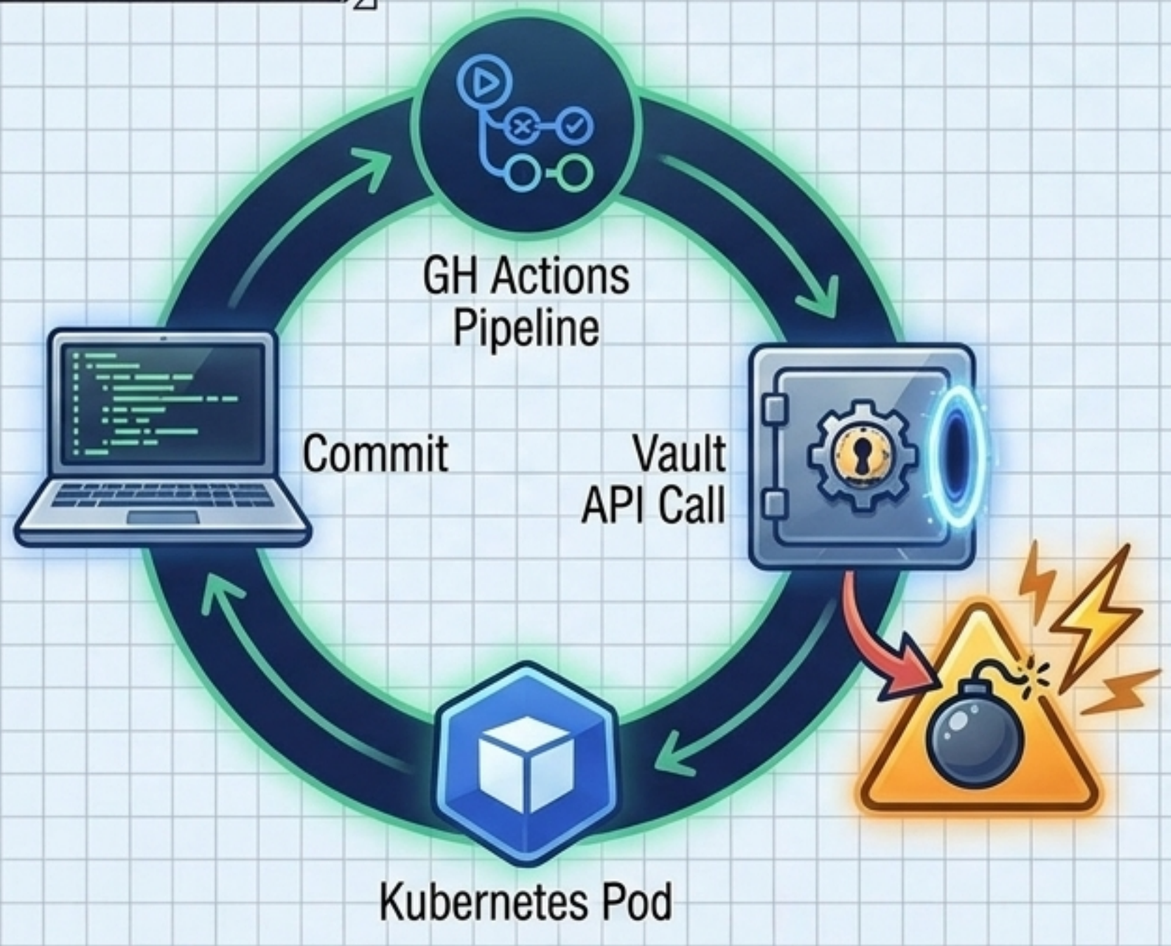
Paso 8: Crear una Política ACL de privilegio mínimo (solo lectura sobre la ruta de la app) y generar un Token único.

Paso 9: Modificar el pipeline de GitHub Actions (usando hashicorp/vault-action) para consumir la API de Vault con el Token generado.

Gemini Notebook

Semana 4 | Pruebas e Inyección en K8s

22 – 26 de Octubre



Paso 10: Prueba de integración completa.

Un commit debe disparar el pipeline, autenticarse, extraer credenciales dinámicamente e inyectarlas en el despliegue del clúster K8s.

Paso 11 (Pruebas de Resiliencia): Simular fallos críticos.

¿Qué sucede en el pipeline si el token expira? ¿Qué pasa si la política ACL cambia o Vault se sella (Sealed)? Validar la robustez del diseño.

Gemini Notebook

Evolución de la Gestión de Secretos

	Código Hardcodeado	Variables en CI/CD	Modelo Vault (DevSecOps)
Visibilidad y Auditoría	Nula. Cualquiera con acceso al repo ve los secretos.	Limitada. Administradores del repo pueden extraerlos.	Total. Logs de auditoría exactos de quién/qué consumió cada secreto.
Rotación de Credenciales	Requiere reescribir código y redesplegar.	Requiere edición manual en configuraciones del pipeline.	Dinámica y centralizada. Actualizas en Vault y las aplicaciones consumen la nueva versión.
Superficie de Ataque	Permanente y masiva.	Media (riesgo de Secret Sprawl).	Mínima (Autenticación de vida corta, principio de menor privilegio).

Gemini Notebook

Criterios de Evaluación y Éxito

Para alcanzar la Fase 3, la ejecución debe ser impecable a través de cuatro dimensiones (25 pts cada una).





Implementación de Seguridad (25 pts)

Servidor Vault operando correctamente con políticas de acceso y motor KV configurado.



Accesibilidad y UI (25 pts)

Interfaz de usuario de Vault habilitada, expuesta de forma segura y accesible web.



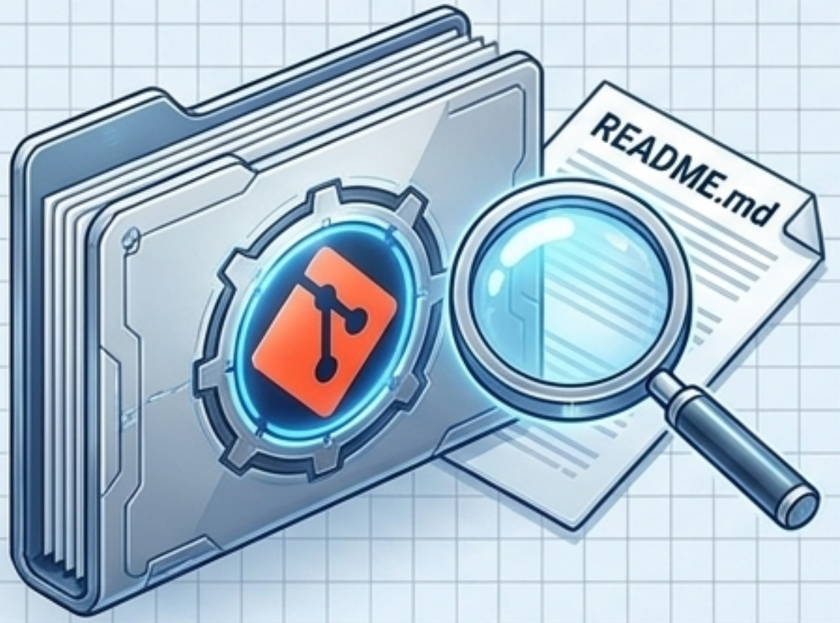
Portafolio de Evidencias (25 pts)

Documentación detallada del proceso, diagramas y capturas de validación.

Gemini Notebook

Entregables Finales (27 – 30 de Octubre)

No basta con que funcione; debe estar documentado como ingeniería de clase mundial.



Bloque 1: Repositorio Git de Trabajo
- Código limpio y estructurado.
- README.md exhaustivo con instrucciones exactas de ejecución de Ansible y arquitectura del proyecto.



Bloque 2: Portafolio de Evidencias
- Capturas de la interfaz web de Vault operando.
- Logs terminales mostrando la ejecución exitosa de Ansible.
- Evidencia del pipeline CI/CD leyendo secretos exitosamente.

El éxito de esta fase sienta las bases definitivas para una verdadera cultura DevSecOps. ¡A construir la Ciudadela!

Gemini Notebook